OTPROOF

AI-powered industrial vulnerability applicability and remediation assurance

80
fictional assets

3
real CISA advisories

0
OT device actions

The idea

Turn public industrial security advisories and operator-maintained asset lists into a reviewable, evidence-backed workflow. Deterministic rules identify exact product and version candidates; people resolve uncertainty and verify remediation.

A practical, safety-conscious MVP

A local dashboard, validated CSV/XLSX inventory import, official public-source ingestion, explainable applicability, engineer/reviewer/approver workflow, audit trail, and assurance report. No OT network interaction is required.

Eureka Hackathon · Product concept and working MVP · 26 October 2026

The problem sits between the inventory and the advisory

A published CVE is not enough to know which operational asset needs engineering attention.

Three records that rarely line up cleanly

Operators track asset names, models, software/firmware, site, criticality, and owners across maintenance records and spreadsheets. Advisory publishers use product families, version ranges, configuration conditions, and vendor terminology. Security and engineering teams reconcile them under time pressure.

False certainty has a cost

A superficial product-name match can create noise; a missing or stale version can hide a relevant case. OT teams must also assess process impact, approved change windows, vendor support, and operational safety before acting.

Why now

NIST SP 800-82 Rev. 3 identifies accurate inventory details such as vendor, model, software/firmware version, location, and roles as useful to OT risk management. It also recognizes that active collection methods may affect OT and need careful consideration. OTProof begins with an operator-supplied inventory and stays out of the control network.

> **The product produces a source-backed triage candidate, not a safety, exploitability, or remediation verdict.**

A single workflow from source to verified evidence

Every finding preserves the records and decisions needed to explain what happened.

1 · Load and validate inventory

Import a CSV or XLSX file with asset identity, vendor, product/model, version, type, site, criticality, owner, and last verification date. Reject duplicate identifiers, oversized uploads, and macro-enabled workbooks.

2 · Import approved advisory data

Fetch CISA ICS RSS/advisory/CSAF, CISA KEV JSON, NVD CVE API 2.0, or a bulletin on an approved vendor HTTPS domain. Cache payloads and preserve source URLs and timestamps.

3–6 · Compare, review, and assure

The deterministic matcher returns applicable, not applicable, or manual verification. An engineer records the applicability decision and rationale; an approver accepts or rejects a proposed ticket; evidence is attached and separately verified by an approver; JSON/PDF reports retain sources and audit history.

A ticket or generated narrative cannot mark a finding remediated. Only an approver verification tied to evidence can.

A modular, offline-capable architecture

One maintainable service keeps source ingestion, comparison, workflow, and evidence close together.

Built for the demo and a controlled pilot

React + TypeScript dashboard → FastAPI/Pydantic API → SQLAlchemy and PostgreSQL. SQLite supports a quick local run. Alembic manages schema changes. ReportLab exports assurance reports. Docker Compose packages the database, API, and frontend.

Public sources only

The ingestion service uses documented CISA RSS/JSON, NVD CVE API 2.0, CISA-linked CSAF documents, and an allowlist of vendor bulletin domains. Conditional cache headers, a configurable TTL, bounded retries, and stale-copy fallback support outages.

Explicit trust boundaries

There is no OT interface, protocol client, scanner, exploit capability, or control action. The optional local LLM adapter receives advisory text only and cannot write applicability decisions or workflow status.

Deployment for real operators requires managed identity, secret rotation, allowlisted egress, backup/restore, and independent security review.

Deterministic matching earns each conclusion

Product identity and version evidence are more useful than an unexplained similarity score.

Supported comparisons

A curated alias map normalizes a small set of known vendor/product variants. Exact normalized product identity is followed by conservative dotted-numeric version comparison against published equality or inclusive/exclusive bounds. Constraints in one NVD CPE match are conjunctive; alternatives remain separate candidate products.

Abstain when evidence is incomplete

Missing firmware, unknown model, possible duplicate asset, inventory older than 180 days, unsupported suffix/version syntax, ambiguous product identity, and compound or negated NVD configurations require an engineering review. Semantic similarity never decides applicability.

AI assists with reading, not deciding

An optional local Ollama-compatible model can draft structured product/version/CVE extraction, summaries, uncertainty explanations, and review suggestions. Pydantic validates the response and extracted identifiers/quotes are checked against the source text. The LLM is not used by the matcher or state machine.

Default model name: Qwen2.5 7B Instruct via Ollama (Apache-2.0 model repository, MIT runtime). No inference was run for this MVP evaluation.

Human decisions create the assurance record

Separate technical applicability, remediation planning, approval, and evidence verification.

Role-gated lifecycle

A reviewer can run analysis and record an applicable/not-applicable decision with a rationale. An engineer can propose a mitigation, owner, and due date. An approver independently accepts/rejects the ticket. Evidence is then attached with a hash and reference; an approver verifies a selected record and supplies a rationale.

Audit and exports

Application actions create append-only audit events with actor, role, timestamp, entity, and details. The report includes source publication/update dates, matching reasons, human decisions, remediation state, evidence references/hashes, and audit history.

What the MVP does not claim

Demo bearer tokens are intentionally visible and unsafe for production. The audit database is not WORM or cryptographically immutable. Evidence is text/metadata rather than binary attachments. No certification, compliance determination, or verified operational-risk reduction is claimed.

The demo evidence is simulated. Verification changes application workflow status; it does not attest to a real plant modification.

Commercial opportunity: focused assurance around OT data

Potential users span operators, contractors, and service providers with different inventory systems.

Interview targets

Water and wastewater utilities; energy operators; oil and gas infrastructure; industrial maintenance contractors; managed OT security service providers; and defense-support facilities. Likely champions are OT security leads, plant engineering managers, asset owners, CISOs, and service-practice owners.

Competitive landscape

Claroty, Tenable, and Nozomi publicly describe broad OT asset visibility, vulnerability/exposure management, monitoring, and remediation workflows. ServiceNow and other GRC/IRM suites manage enterprise risk, controls, audit, and work processes. OTProof's possible wedge is a local, source-linked and conservative review workflow that may complement existing products; this is a hypothesis, not a demonstrated product advantage. Better evidence handover may support audit preparation and help operators review exposure sooner, but neither compliance outcomes nor risk reduction have been measured.

Illustrative annual revenue model

Assume 3 licensed sites per customer at $36,000/site/year; $25,000 onboarding per new customer; 78% recurring software gross margin; and 40% onboarding-services gross margin. The scenarios below are arithmetic examples only—not bookings, market sizing, or a forecast.

Customers	Sites	Recurring ARR	Year-1 revenue	Year-1 gross profit
1	3	$108k	$133k	$94k
5	15	$540k	$665k	$471k
10	30	$1.08m	$1.33m	$942k
25	75	$2.70m	$3.33m	$2.36m

Other revenue paths: enterprise license, integrations, deployment, and ongoing assurance services. Price and margin assumptions need buyer interviews and cost validation.

Measured MVP, open questions, and the next proof points

The first test is repeatable behavior against labeled edge cases—not a broad product claim.

Fixture baseline (26 Oct 2026)

14 labeled asset/advisory pairs: 4 applicable, 4 not applicable, and 6 expected manual verification. The deterministic matcher produced 14/14 expected labels, 100% precision/recall on four positive fixture examples, 0 labeled false negatives, and 6/6 expected abstentions. Every labeled result retained source ID, URL, and excerpt.

Performance and security checks

One in-process pass over 80 assets × 3 advisories (240 pairs) measured about 1.01 ms on the development machine; this excludes network, database, and human review. Tests cover stale-cache fallback, duplicate IDs, macro-enabled workbook rejection, source quote validation, prompt injection as untrusted data, role authorization, and remediation evidence verification.

Roadmap and pilot ask

Next: (1) invite 3–5 operator design partners, (2) label a diverse, source-reviewed multi-vendor dataset, (3) run blinded engineering adjudication and measure false negatives/abstentions, (4) add SSO, durable audit export, and CMMS/GRC connectors, (5) conduct a threat model and deployment review. Ask: a water/energy operator and OT engineers to validate the workflow, data fields, and trust boundaries.

Human review time, AI extraction accuracy, field accuracy, cost savings, and production performance remain unmeasured.

NIST SP 800-82 Rev. 3 final: https://csrc.nist.gov/pubs/sp/800/82/r3/final
CISA advisory fixture provenance: data/fixtures/SOURCES.md
Technology and competitive references: docs/TECHNOLOGY_DECISIONS.md and docs/RESEARCH_NOTES.md